

reports compile knowledge from incidents reported by many organizations worldwide. Different types of information supporting an assessment may be available through the following:

- Incident data from reports published by security providers and others.
- Attack data from sources including FS-ISAC and managed security service providers.
- Threat data through reports available either free or for a fee.

The availability of threat information is often ad hoc, although some providers present threat information within a defined framework that readily lends itself to analytical operations. By using a threat taxonomy, the institution may greatly reduce the complexity of threat assessment and enable efficient understanding of reasonable risk mitigations. Specific factors in the threat assessment may include a description, context for operation, capabilities and intent, and, from the threat-source perspectives, benefits and negative consequences associated with an attack.

Knowledge of threat sources is especially important to help identify vulnerabilities. Vulnerabilities can occur in many areas, such as the system design, the system operation, security procedures, business line controls, and the implementation of the system and controls. Self-assessments, audits, scans, penetration tests, and reviews of SIEM reports can identify vulnerabilities. Additionally, external individuals or groups can identify vulnerabilities.

Tools for analyzing vulnerabilities in a layered security environment include attack trees, event trees, and kill chains. These tools attempt to model an attacker's actions to enable identification of the most effective and efficient remediation options.

Once a threat is identified and potential vulnerabilities are assessed, the significance of the threat should trigger a response. The response should be commensurate with the risk posed by the threat and should include remediation options. Management should design policies to allow for immediate and consequential threats to be dealt with expeditiously, while less significant threats are addressed as part of a broader risk management process. When management receives vulnerability information from external individuals or groups, management should have appropriate processes and procedures to evaluate the credibility of the information to appropriately address it.

III.B Threat Monitoring

Threat monitoring policies should provide for continual and ad hoc monitoring of threat intelligence communications and systems, effective incident detection and response, and the use of monitoring reports in subsequent legal procedures. Management should establish the responsibility and authority of security personnel and system administrators for monitoring. Additionally, management should review and approve the tools used and the conditions for use.

Threat monitoring should address indicators of vulnerabilities, attacks, compromised systems, and suspicious users, such as those who do not comply with or seek to evade security policies. Monitoring should address incoming and outgoing network traffic, seeking to identify malicious activity and data exfiltration. Additionally, the monitoring process should be established and documented to independently monitor administrators and other users with higher privileges.

III.C Incident Identification and Assessment

Action Summary

Management should have a process to enable the following:

- Identify indicators of compromise.
- Analyze the event associated with the indicators.
- Classify the event.
- Escalate the event consistent with the classification.
- Report internally and externally as appropriate.

Incident identification involves indicators and analysis. External indicators may arise through contact with customers, law enforcement, card organizations (e.g., credit or payment cards), other financial institutions, media, or others. Internal indicators may arise when internal users contact the help desk, IT operations follows up on anomalies, or security operations follows up on anomalies identified through security devices and network and systems activity. Indicators may also arise through the use of “hunt teams,” or dedicated analysts who actively search for indicators of compromise. Examples of technology-based intrusion identification systems and tools include the following:

- Threat intelligence data feeds (e.g., STIX/TAXII).⁶⁰
- Intrusion detection and prevention systems for networks and hosts.
- End-point visibility tools (tools that can identify the function of end points and which end points contain or have access to sensitive information).
- DLP tools.
- Log correlation and analysis tools.
- File integrity tools.
- Malware detection tools.
- Network behavior analysis systems.
- “Big data” tools and analytics that aggregate and allow pre-formed and ad hoc analysis.

Technology-based indicators of compromise generally are anomalies in host state, host activity, and network traffic. A few examples are unexpected (1) processes, (2) changes to files, (3) packet source or destination, (4) protocols, (5) ports, (6) encryption, (7) log-ins, and (8) packet content. Other indicators include alerts triggered by black lists in anti-virus and network-monitoring products.

Management should have a process for identifying indicators of compromise and rapidly reporting those indicators for investigation. The report should instigate an analysis that seeks to

⁶⁰ There are efforts to automate and structure operational cybersecurity information-sharing techniques across the globe. Of these, STIX (the Structured Threat Information eXpression) and TAXII (the Trusted Automated eXchange of Indicator Information) are two of the technical specifications that allow an automated exchange of threat source data using standardized language.

confirm whether a compromise took place and how that compromise should be classified. Investigation may require additional information from outside and inside the institution, such as a forensic review. Management should perform due diligence to identify external assistance in advance of incidents to ensure available resources. Classification of a compromise may require information on the specific hosts affected, data lost, and business processes affected. Information developed in the analysis may be useful to guide response activities.

Analysis should result in a classification of the event, implementation of escalation procedures, and reporting. Analysis should be guided by the following:

- Classification policies should be sufficiently clear to enable timely classification of incidents by level of severity, enabling the use of response teams and responses depending on the type and severity of events.
- Escalation, response, and reporting should be commensurate with the level of severity.
- Escalation policies should address when different personnel within the organization will be contacted and the responsibility those personnel have in incident analysis and response.
- Escalation policies should include when to request or obtain external assistance, from both third parties and the federal government.
- Reporting policies should address internal and external reporting, including coordination with third parties and reporting to external organizations (e.g., FS-ISAC).

Additionally, a policy should address who is empowered to declare an incident. A defined process should guide responses to incidents. The institution should develop procedures to test the incident escalation, response, and reporting processes.

The sharing of attack data through organizations, such as FS-ISAC, also has the potential to benefit the industry at large by enabling other institutions to better assess and respond to current attacks. Management should consider whether to include such information sharing as a part of its strategy to protect the institution.

Management should determine whether the institution's or its managed security service provider's analysts are sufficiently trained to appropriately analyze network, host, and application activity and to use the monitoring and analysis tools made available to them. Additionally, security analysts should coordinate and collaborate with others in the institution with knowledge and authority for specific types of malicious activity, such as fraud.

III.D Incident Response

Management should have an incident response program.⁶¹ The goal of incident response is to minimize damage to the institution and its customers. The institution's program should have defined protocols to declare and respond to an identified incident. More specifically, the incident response program should include, as appropriate, containing the incident, coordinating with law

⁶¹ See also "Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice," supplementing the Information Security Standards.

enforcement and third parties, restoring systems, preserving data and evidence, providing assistance to customers, and otherwise facilitating operational resilience of the institution.

The response involves a combination of people and technologies. The quality of incident response is attributable to the institution's culture, policies, procedures, and training. Incident response is also a function of the relationships the institution formed before the incident with law enforcement, incident response consultants and attorneys, information-sharing entities (e.g., FS-ISAC), and others. Management should prepare for potential incidents by developing an incident response plan that is comprehensive, coordinated, and integrated with existing institution policies, procedures, and training. To validate the effectiveness of the institution's incident response program, management should periodically test it through different test types, including scenario planning and tabletop testing, and perform the tests with appropriate internal and external parties.

Preparation determines the success of any intrusion response. Such preparation involves defining the policies and procedures that guide the response; assigning responsibilities to individuals; providing appropriate training; formalizing information flows; and selecting, installing, and understanding the tools used in the response effort. Additionally, management should define thresholds for reporting significant security incidents, and consider developing processes for when the institution should notify its regulators of incidents that may affect the institution's operations, reputation, or sensitive customer information. These incidents may include those that could affect the financial system. Primary considerations for incident response include the following:

- How to balance concerns regarding confidentiality, integrity, and availability for devices and data. This consideration is a key driver for a containment strategy and may involve legal and liability considerations. Management may decide that some systems must be disconnected or shut down at the first sign of intrusion, while others must be left on line.
- When and under what circumstances to invoke the incident response activities, and how to ensure that the proper personnel are notified and available.
- When to involve outside experts and how to ensure the proper expertise will be available when needed. This consideration addresses both containment and restoration.
- Protocols to define when and under what circumstances to notify and involve regulators, customers, and law enforcement, including names and contact information for each group.
- Which personnel have authority to perform specific actions in the containment of the intrusion and restoration of the system. This consideration affects the internal communications strategy, the commitment of personnel, and procedures that escalate involvement and decisions within the organization.
- How, when, and what to communicate outside of the institution, whether to law enforcement, regulatory agencies, information-sharing organizations, customers, third-party service providers, potential victims, or others.
- How to document and maintain the evidence, the decisions made, and the actions taken.
- What criteria must be met before compromised services, equipment, and software are returned to the network.
- How to learn from the intrusion and use lessons learned to improve the institution's security.
- How and when to prepare and file a Suspicious Activities Report.

Successful implementation of any response policy or procedure requires the assignment of responsibilities, training, and testing. Some institutions formalize the response program with the creation of a security incident response team (SIRT). The SIRT typically is tasked with performing, coordinating, and supporting responses to security incidents and intrusions. Because of the wide range of technical and nontechnical issues posed by an intrusion, typical SIRT membership includes individuals with a wide range of backgrounds and expertise from different areas within the institution. Those areas include management, legal, and public relations, as well as IT staff. Other organizations may outsource some of the SIRT functions (e.g., forensic examinations). When SIRT functions are outsourced, management should require the third-party service provider to follow the institution's policies and maintain the confidentiality of data.

Institutions should assess the adequacy of their preparation through testing. There are a variety of testing methods; therefore, management should consider the most applicable tests for its IT environment. Institutions can also participate with outside entities that provide testing activities (e.g., FS-ISAC).

While containment strategies between institutions can vary, they typically include the following broad elements:

- Isolation of compromised systems or enhanced monitoring of intruder activities.
- Search for additional compromised systems.
- Collection and preservation of evidence.
- Communication with affected parties and often the primary regulator, information-sharing organizations (e.g., FS-ISAC), or law enforcement.

Restoration and follow-up strategies should address the following:

- Elimination of an intruder's means of access.
- Restoration of systems, programs, and data to a known good state.
- Initiation of customer notification and assistance activities consistent with laws, regulations, and interagency guidance.
- Monitoring to detect similar or further incidents.

Management should periodically review the actions taken in response to intrusions to identify improvements and implement those improvements through changes in policy, standards, procedures, training, and practices.

IV Information Security Program Effectiveness

The information security program should be subject to periodic review to ensure continual improvement in the program's effectiveness. The review should address the program in the context of the environment in which the program now operates, both within the institution and outside. Lessons learned from experience, audit findings, and other indicators of opportunities for improvement should be identified and the program changed as appropriate.

IV.A Assurance and Testing

Action Summary

Management should ascertain that the information security program is operating securely, as expected, and reaching intended goals by doing the following:

- Testing and evaluating through self-assessments, tests, and audits with appropriate coverage, depth, and independence.
- Aligning personnel skills and program needs.
- Establishing and implementing a reporting process that includes the assembly and distribution of assurance reports that are timely, complete, transparent, and relevant to management decisions.

Assurance relates to the confidence that the information security program is mitigating risk as expected. Assurance targets two parts of the process: (1) the IT system's design and (2) the IT system's operation. The institution should carefully distinguish between the two because the former relates to risk decisions that change the security controls and the latter relates to the operation of the controls. Flaws in control design typically are corrected by a redesign, and flaws in operation typically are corrected through a compliance program.

The institution should have a documented testing and evaluation plan that addresses the integration of security controls, level of assurance desired, and strategies and activities performed in obtaining that assurance. The plan should identify specific components of the system to address, methods by which the components are to be addressed, timing and frequency of the tests and evaluations, and criteria used to ascertain whether the test and evaluation results are acceptable and provide assurance.⁶²

IV.A.1 Key Testing Factors

Management should consider the following key factors when developing and implementing independent tests:

- **Scope.** The tests and methods utilized, in the aggregate, should be sufficient to validate the effectiveness of the security process in identifying and appropriately controlling the risk from information security-related events.
- **Personnel.** Technical testing is only as good as the personnel performing and supervising the test. Management should review qualifications of testing personnel to verify testers' capabilities are adequate to support the test objectives.
- **Notifications.** Management should consider whom to inform within the institution about the timing and nature of the tests. The need for protection of institution systems and the potential for disruptive false alarms should be balanced against the need to test personnel reactions to unexpected activities.

⁶² See also Information Security Standards, section III.C.3, requiring each financial institution to test the key controls, systems, and procedures of its information security program using independent third parties or staff independent of those that develop or maintain the program.

- **Confidentiality, integrity, and availability.** Management should carefully control information security tests to limit the risks to confidentiality, integrity, and system availability. Because testing may uncover sensitive customer information, management should use appropriate safeguards to protect such information. Management should ensure that employee and contract personnel who perform the tests or have access to the test results have passed appropriate background checks and that contract personnel are appropriately bonded. Because certain tests may pose more risk to system availability than other tests, management should have personnel who perform those tests maintain logs of testing actions. Those logs are helpful if the systems react unexpectedly.
- **Confidentiality of test plans and data.** Because knowledge of test planning and results may facilitate a security breach, the institution should carefully limit the distribution of testing information. Management should restrict test plans and data only to those individuals involved in the testing. Results should be made available in a usable form only to those responsible for following up on tests. Additionally, management should require contractors to sign nondisclosure agreements and to return information they obtained in their testing to the institution.
- **Frequency.** The institution's ITRM process should determine the frequency of independent testing. Factors that may increase testing frequency include changes to network configurations, changes to or additions of systems and applications, significant changes in potential attacker profiles and techniques, and results of other testing. For instance, management should have a testing process for security and usability over the life cycle of testing (during development, before placing a new or modified system into production, and periodic testing of the production system or application).
- **Proxy testing.** Proxy testing refers to testing that is conducted on like systems and with like interfaces, rather than the actual system, to avoid disruptions on a system that may be too critical for a comprehensive continuity test. Proxy tests are conducted using the same hardware and operating software, are sometimes used as a replacement for actual tests, and should provide similar results. Independent testing of a proxy system is generally not effective in validating the effectiveness of a security process. Proxy testing, by its nature, does not test the operational system's policies and procedures or its integration with other systems. It also does not test the reaction of personnel to unusual events. Proxy testing may be the best choice, however, when management is unable to test the operational system without creating excessive risk.

IV.A.2 Types of Tests and Evaluations

Information security management may use several tools to gain confidence that the information security program is operating as expected and reaching the intended goals. The primary tools include self-assessments, penetration tests, vulnerability assessments, and audits. The coverage and depth of the various tools directly relates to the confidence gained in the information security program.

IV.A.2(a) *Self-Assessments*

Periodic self-assessments typically should be performed by the organizational unit being assessed. Self-assessments capture subjective opinions on the achievement of objectives.

Although they may provide valuable information related to perceived changes in the level of risk and effectiveness of controls, they are affected by the breadth and depth of the assessor's knowledge, the completeness and reliability of information used to complete the assessment, and the assessor's biases. Self-assessment frequency should be a function of the level of assurance needed by the institution, determined by the risk management process. Results from self-assessments can be informative to the overall test and evaluation process. Management should use the results to help strengthen the organizational unit's information security.

IV.A.2(b) *Penetration Tests*

A penetration test subjects a system to real-world attacks selected and conducted by the testers. A penetration test targets systems and users to identify weaknesses in business processes and technical controls. The test mimics a threat source's search for and exploitation of vulnerabilities to demonstrate a potential for loss. Some tests focus on only a subset of the institution's systems and may not accurately simulate a determined threat actor. There are many types of penetration tests (e.g., network, client-side, web application, and social engineering), and management should determine the level and types of tests employed to ensure effective and comprehensive coverage.

The frequency and scope of a penetration test should be a function of the level of assurance needed by the institution and determined by the risk assessment process. The test can be performed internally by independent groups, internally by the organizational unit, or by an independent third party. Management should determine the level of independence required of the test.

IV.A.2(c) *Vulnerability Assessments*

A vulnerability assessment is a process that defines, identifies, and classifies the vulnerabilities in a computer, network, or communications infrastructure. Technical vulnerabilities can be identified through the use of scanners and other tools. Scanners search for known vulnerabilities (e.g., Mitre's CVE) or for known vulnerability classes (e.g., Structured Query Language [SQL] injection and cross-site scripting). They also can search for compliance with approved configurations. Scanners identify vulnerabilities by inspecting network traffic or hosts. When inspecting hosts, they may require agents to be placed on the hosts with high-level access. If host agents are required, the security over the use of credentials in the scan should be a prime consideration for management.

Similar to penetration testing, the frequency of the performance of vulnerability assessments should be determined by the risk management process. Scanners and other tools can be run continuously, generating metrics that are reported and acted upon continuously. Alternatively, they can be run periodically. Vulnerability assessments can be performed internally or by external testers, but they are often run as part of internal testing processes.

IV.A.2(d) Audits

Independent internal departments or third parties typically perform audits. Audits should review every aspect of the information security program, the environment in which the program runs, and outputs of the program. Audits should assess the reasonableness and appropriateness of, and compliance with, policies, standards, and procedures; report on information security activity and control deficiencies to decision makers; identify root causes and recommendations to address deficiencies; and test the effectiveness of controls within the program. Internal audit should track the results and the remediation of control deficiencies reported in audits and additional technical reviews, such as penetration tests and vulnerability assessments.

Refer to the *IT Handbook's* "Audit" booklet for more information.

IV.A.3 Independence of Tests and Audits

Institutions frequently use independent organizations to test aspects of their information security programs. Independent tests have the potential to reduce bias, increase capabilities, and increase knowledge about threats and technologies. Independence gives credibility to the test results. To be considered independent, testing personnel should not be responsible for the design, installation, maintenance, and operation of the tested system, or the policies and procedures that guide its operation. The reports generated from the tests should be prepared by individuals who similarly are independent.

IV.A.4 Assurance Reporting

Reporting of self-assessments, penetration tests, vulnerability assessments, and audits supports management decision making. Those decisions may support a range of ITRM activities, including the prioritization and funding of resource allocations and improvement to existing information security policies and procedures.

Management should provide reports that are timely, complete, transparent, and relevant to management decisions. The reports should prioritize risk and findings in the order of importance, suggest options for remediation, and highlight repeat issues. Additionally, reports should address root causes. The reporting should be to individuals with authority and responsibility to act on the reports and to those accountable for the outcomes, as well as those responsible for advising or influencing risk decisions. Reporting should trigger appropriate, timely, and reliable escalation and response procedures. Summary reports should be made available to the board as appropriate.

Appendix A: Examination Procedures

Examination Objective

Determine the quality and effectiveness of the institution's information security. Examiners should use these procedures to measure the adequacy of the institution's culture, governance, information security program, security operations, and assurance processes. In addition, controls should be evaluated as additional evidence of program quality and effectiveness. Controls also should be evaluated for conformance with contracts, indicators of legal liability, and conformance with regulatory policy and guidance. Failure of management to implement appropriate controls may expose the institution to potential loss from fines, penalties, and customer litigation.

These examination procedures (commonly referred to as the work program) are intended to help examiners determine the effectiveness of the institution's information security process. Examiners may choose, however, to use only particular components of the work program based on the size, complexity, and nature of the institution's business. Examiners should also use these procedures to measure the adequacy of the institution's cybersecurity risk management processes.

Objective 1: Determine the appropriate scope and objectives for the examination.

1. Review past reports for outstanding issues or previous problems. Consider the following:
 - a. Regulatory reports of examination.
 - b. Internal and external audit reports.
 - c. Independent security tests.
 - d. Regulatory, audit, and security reports on service providers.
2. Review management's response to issues raised at, or since, the last examination. Consider the following:
 - a. Adequacy and timing of corrective action.
 - b. Resolution of root causes rather than just specific issues.
 - c. Existence of any outstanding issues.
3. Interview management and review responses to pre-examination information requests to identify changes to technology infrastructure or new products and services that might increase the institution's risk. Consider the following:
 - a. Products or services delivered to either internal or external users.
 - b. Network topology or diagram including changes to configuration or components and all internal and external connections.
 - c. Hardware and software inventories.
 - d. Loss, addition, or change in duties of key personnel.
 - e. Technology service providers and software vendor listings.